

PHƯƠNG PHÁP THỰC HIỆN

1. Lựa chọn phương pháp tiếp cận

Dựa trên yêu cầu của đề án cuối kỳ, nhóm áp dụng phương pháp tiếp cận thực chiến thông qua việc xây dựng một hệ thống SOC thu nhỏ (Hunting Range). Kịch bản thực nghiệm được thiết kế theo mô hình tác chiến đối kháng giữa đội tấn công (Red Team) và đội phòng thủ (Blue Team). Toàn bộ kiến trúc được triển khai trên môi trường máy ảo, sử dụng mạng riêng ảo Tailscale để đảm bảo các nút mạng giao tiếp thông suốt, mô phỏng chính xác cấu trúc mạng phân tán trong thực tế.

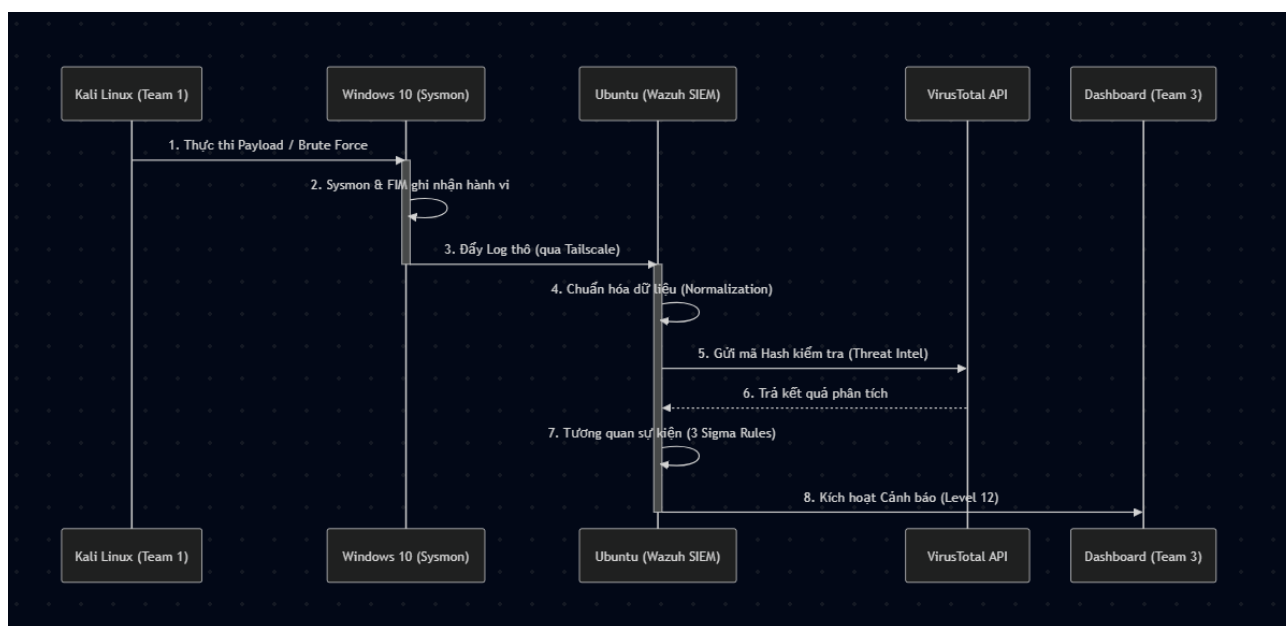
2. Thiết kế hệ thống và luồng xử lý

2.1. Thiết kế hệ thống

Hệ thống giám sát được thiết kế với 3 phân hệ cốt lõi, tương ứng với sự phối hợp chặt chẽ của 3 vai trò trong đội ngũ:

- Phân hệ Tấn công (Red Team): Sử dụng Kali Linux làm trung tâm điều khiển (C2). Chịu trách nhiệm thực thi chuỗi tấn công bao gồm phát tán mã độc (payload.exe) và dò quét mật khẩu (Brute Force) vào mục tiêu.
- Phân hệ Hạ tầng (SOC Engineer): Xây dựng máy chủ SIEM Wazuh trên nền tảng Ubuntu. Thiết lập Sysmon trên máy nạn nhân (Windows 10) để trích xuất nhật ký sự kiện. Tích hợp API VirusTotal nhằm tự động hóa quá trình làm giàu dữ liệu (Threat Intel).
- Phân hệ Săn lùng (Threat Hunter): Hoạt động trên giao diện Web Dashboard của SIEM. Giám sát luồng dữ liệu, thực hiện phân tích tương quan (Alert Correlation) và áp dụng các tệp quy tắc (Sigma Rules) để nhận diện, định vị sự cố.

2.2. Sơ đồ luồng xử lý



Hình 1 : Sơ đồ luồng xử lý

Bước 1: Thực thi Payload / Brute Force (Giai đoạn tấn công): Đội Red Team sử dụng Kali Linux để phát động tấn công trực tiếp vào máy nạn nhân Windows 10.

Bước 2: Sysmon & FIM ghi nhận hành vi (Giai đoạn thu thập): Tại máy nạn nhân, các cảm biến giám sát (Sysmon và FIM) lập tức phát hiện các bất thường và tiến hành ghi log.

Bước 3: Đẩy Log thô qua Tailscale (Giai đoạn truyền tải): Wazuh Agent trên Windows 10 đóng gói log thô và gửi về máy chủ trung tâm thông qua mạng riêng ảo Tailscale.

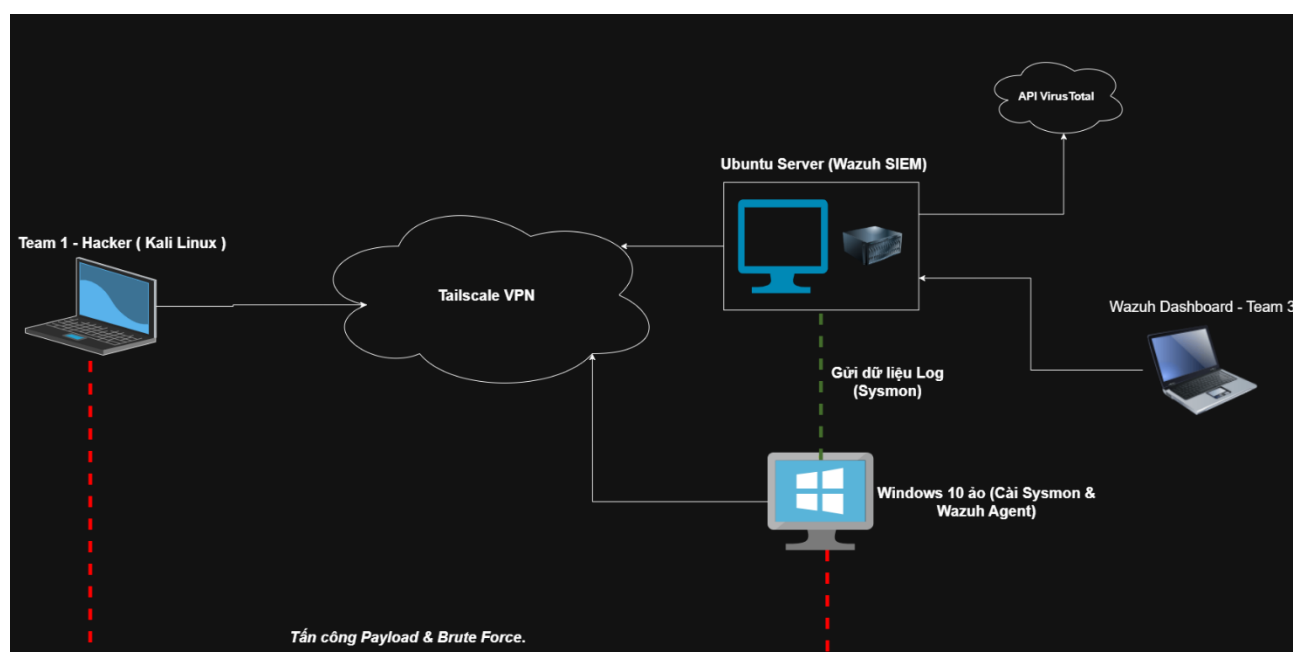
Bước 4: Chuẩn hóa dữ liệu - Normalization (Giai đoạn tiền xử lý): Máy chủ SIEM tiếp nhận dữ liệu thô, tiến hành bóc tách và chuẩn hóa để đưa về một định dạng phân tích thống nhất.

Bước 5 & 6: Làm giàu dữ liệu (Threat Intel): Hệ thống tự động trích xuất mã Hash của tệp tin nghi ngờ và gửi truy vấn qua API đến VirusTotal để định danh mức độ độc hại.

Bước 7: Tương quan sự kiện (Giai đoạn phân tích tự động): Engine của Wazuh thực hiện đối chiếu dữ liệu đã chuẩn hóa với các bộ quy tắc phát hiện (Sigma Rules) đã được cấu hình.

Bước 8: Kích hoạt cảnh báo (Giai đoạn phản hồi): Khi điều kiện thỏa mãn, hệ thống kích hoạt cảnh báo an ninh mức độ nghiêm trọng (Level 12) trên giao diện Dashboard, giúp Threat Hunter lập tức ánh xạ vào khung MITRE ATT&CK.

3. Sơ đồ kiến trúc mạng



Hình 1: Sơ đồ kiến trúc mạng

- Mô hình mạng của hệ thống được thiết kế theo kiến trúc phân tán nhưng được kết nối bảo mật và quản lý tập trung. Luồng giao tiếp giữa các thành phần được diễn giải cụ thể như sau:

+ Hạ tầng mạng cốt lõi (Tailscale VPN): Đóng vai trò là trục xương sống (Backbone) của toàn bộ hệ thống. Tailscale tạo ra một mạng lưới LAN ảo được mã hóa, cho phép cả 3 máy tính (máy tấn công, máy nạn nhân, và máy chủ SIEM) dù nằm ở các

môi trường vật lý khác nhau vẫn có thể "nhìn thấy" và giao tiếp với nhau một cách thông suốt, an toàn.

+ Phân hệ Tấn công (Team 1 - Hacker / Kali Linux): Đây là điểm phát động chiến dịch. Thông qua đường hầm VPN, kẻ tấn công xác định được IP nội bộ của máy nạn nhân và tiến hành phóng các luồng tấn công (như gửi Payload độc hại, dội bom mật khẩu Brute Force) trực tiếp vào thiết bị mục tiêu (*thể hiện qua đường nét đứt màu đỏ*).

+ Phân hệ Mục tiêu & Thu thập dữ liệu (Windows 10 ảo): Là thiết bị chịu tác động của các cuộc tấn công. Tại đây, công cụ Sysmon hoạt động ở tầng nhân (Kernel) liên tục ghi nhận các sự kiện bất thường. Tác nhân Wazuh Agent được cài đặt trên máy này có nhiệm vụ thu gom toàn bộ tệp nhật ký (Log) từ Sysmon và đẩy an toàn về máy chủ trung tâm qua đường truyền VPN (*thể hiện qua đường nét đứt màu xanh lá*).

+ Phân hệ Xử lý Trung tâm (Ubuntu Server - Wazuh SIEM) & Nguồn tình báo (API VirusTotal): Đây là "bộ não" của hệ thống phòng thủ. Máy chủ Ubuntu tiếp nhận log thô từ máy nạn nhân, chuẩn hóa và đối chiếu với các bộ luật (Sigma Rules). Đặc biệt, hệ thống này được cấu hình để giao tiếp với đám mây của API VirusTotal (Threat Intel) nhằm gửi các mã băm (Hash) của tệp tin đáng ngờ đi kiểm tra, giúp làm giàu dữ liệu cảnh báo trước khi hiển thị.

+ Phân hệ Giám sát SOC (Wazuh Dashboard - Team 3): Là giao diện tương tác cuối cùng của chuyên gia phân tích (Threat Hunter). Máy tính quản trị viên sẽ truy cập vào Dashboard được lưu trữ trên Ubuntu Server thông qua trình duyệt web để theo dõi dòng sự kiện, nhận Cảnh báo Đỏ (Alerts) theo thời gian thực và tiến hành truy vết, ứng phó sự cố.